AI-Powered Data Governance for PIPEDA Compliance: An Evidence-Based Assessment of OpenMetadata in a Canadian Bank

Kshitij Vengurlekar, [Team Member 2], [Team Member 3], [Team Member 4], and [Team Member 5]

Abstract

Problem. Canadian banks hold large volumes of personal information in transactional (OLTP) systems and copy much of it into analytical (OLAP) warehouses, where it is reused for marketing, fraud and regulatory reporting. The *Personal Information Protection and Electronic Documents Act* (PIPEDA) requires organizations to know where this information is, why it is held, who may use it and when it must be destroyed. Data-governance platforms now promise to automate much of this work with artificial intelligence (AI). **Question.** *How, and with what professional safeguards, can a Canadian bank use an open-source, AI-assisted metadata platform to operationalize PIPEDA's fair information principles across its OLTP and OLAP data?* **Method.** We combined a structured review of 45 scholarly, regulatory, standards, professional and patent sources with a reproducible Docker proof of concept (POC) built on OpenMetadata 2.0.5 and a synthetic bank of 1,500 customers. Auto-classification was scored against column-level ground truth. **Findings.** Out-of-the-box AI classification found 72% of personal-information columns and only 4 of 7 high-risk identifiers; several Canadian Social Insurance Numbers were caught only because Australian and U.S. patterns happened to match. Canada-specific recognizers raised recall to 100% (F1 0.783→0.943), and a human feedback workflow removed the remaining false positives. Metadata controls exposed planted PIPEDA defects (55 customers e-mailed after withdrawing consent, 38 records past retention, 1,239 stored card-verification values), but the platform governs the *catalogue*, not the data: enforcement required tag-driven controls generated into the warehouse. **Implications and recommendations.** AI makes a personal-information inventory feasible at scale, but only as a supervised control: banks should (i) localize classifiers for Canadian identifiers, (ii) keep humans accountable for every classification decision, (iii) connect catalogue metadata to enforcement and testing, and (iv) govern AI assistants that query the catalogue as privileged users.

Index Terms

Data governance, PIPEDA, privacy, metadata management, data catalogs, auto-classification, personally identifiable information, OpenMetadata, Model Context Protocol, banking, professional responsibility.

I. Introduction and Problem Context

A Canadian bank's customer data rarely stays where it was collected. A Social Insurance Number (SIN) captured at account opening sits in a core-banking database, flows nightly into a dimensional warehouse [1], and from there into marts for marketing, anti-money-laundering (AML) reporting and analytics. Each copy is "personal information" under PIPEDA [2], and each must respect the ten fair information principles of Schedule 1: accountability, identifying purposes, consent, limiting collection, limiting use and retention, accuracy, safeguards, openness, individual access, and challenging compliance. The professional problem is that most banks cannot answer basic questions about these copies: which columns hold personal information, why, who may read them, and when they should be deleted.

GNG/ELG 5301 Professional Skills and Responsibility, University of Ottawa, Fall 2026. Instructor: Prof. M. Alnabhan.

The organization studied, "Borealis Bank of Canada," is fictional and all data are synthetic. Proof-of-concept code and evidence: `poc/` in the project repository.

A. Why it matters

The consequences of not knowing are concrete. The Office of the Privacy Commissioner of Canada (OPC) found that the 2019 Desjardins breach, which exposed SINs, birth dates and transaction histories of about 9.7 million people, followed from failures of accountability, retention and safeguards, including data that were kept longer than necessary in two data warehouses that an insider could reach [3]. Prudential regulators now expect the same discipline: OSFI Guideline B-13 requires federally regulated financial institutions to identify, classify and protect data by confidentiality and to run periodic discovery scans [4], and Guideline E-23 (effective May 2027) extends model-risk management to AI systems [5]. Federal privacy reform is also in motion: Bill C-27 died in January 2025 and Bill C-36, the *Protecting Privacy and Consumer Data Act*, received first reading in June 2026 [6]. Meanwhile, privacy teams increasingly own AI governance [7].

B. Stakeholders

The problem affects *customers* (whose information is at risk), the *Chief Privacy Officer* (CPO) who is accountable under Principle 4.1, *data stewards and engineers* who build and document pipelines, *business users* in marketing and AML who need data, *regulators* (OPC, OSFI, FINTRAC), and *executives* who carry legal, reputational and financial risk. Their interests partly conflict: business users want broad access, privacy staff want minimization, and engineers want automation that does not slow delivery.

C. Objectives

The project aims to (1) synthesize credible evidence on how AI-assisted metadata platforms support privacy compliance; (2) test those claims on a realistic but synthetic Canadian bank; (3) identify the professional responsibilities that AI features create rather than remove; and (4) recommend actionable steps for a bank's privacy and data leadership.

II. Research Question and Scope

Primary question. *How, and with what professional safeguards, can a Canadian bank use an open-source, AI-assisted metadata platform (OpenMetadata) to operationalize PIPEDA's fair information principles across its OLTP and OLAP data?*

Sub-questions. SQ1: How accurately do AI auto-classification features locate personal information in Canadian banking data, and what improves them? SQ2: Which PIPEDA principles can catalogue metadata, workflows and tests support, and which remain outside their reach? SQ3: What accountability mechanisms must surround the AI features for the resulting controls to be professionally defensible?

In scope. Structured data in relational OLTP and OLAP stores; OpenMetadata 2.0.5 (open source) and its AI features (Presidio/spaCy-based auto-classification [8], recognizer-feedback workflows, the Model Context Protocol (MCP) server [9]); PIPEDA and the federal financial-sector guidance that intersects it.

Out of scope. Unstructured documents and images; commercial catalogues (compared only through the literature); provincial private-sector laws such as Quebec's Law 25; legal advice. We do not collect human-participant data: the bank and all records are synthetic, in line with the course's research-ethics rules.

Assumptions. The bank's retention schedule (seven years after the end of a relationship) is an internal policy assumption consistent with FINTRAC's minimum five-year record-keeping rule [10]; Bill C-36 is treated as forthcoming, not as law.

III. Method and Evidence Process

A. Search strategy and source selection

We searched Crossref, Google Scholar, IEEE Xplore, the ACM Digital Library, SpringerLink, arXiv, Google Patents, the Justice Laws website, and the websites of the OPC, OSFI, FINTRAC, NIST, ISO, BIS and IAPP between October 15 and 21, 2026. Search strings combined three concept blocks: (*data governance* OR *data catalog* OR *metadata* OR *lineage*) AND (*privacy* OR *PIPEDA* OR *personal information* OR *PII*) AND (*automat** OR *machine learning* OR *AI* OR *classification*). The search log is in Appendix B.

Inclusion criteria were: peer-reviewed or authoritative (regulator, standards body, recognized professional association, granted patent, or official product documentation); directly relevant to a sub-question; and verifiable through a DOI, publisher record or official URL. We excluded vendor marketing, undated web content, and any reference we could not verify. Every DOI was checked against Crossref metadata and every URL was retrieved on October 21, 2026. Forty-five sources were retained: 11 journal articles, 2 conference papers and preprints, 4 handbooks and technical books, 10 statutes, bills and regulator publications, 8 standards and technical reports, 3 patents, 1 professional publication, and 6 technical documentation sources (Appendix A).

B. Evidence organization and analytical approach

Each source was coded in an evidence table (source, type, focus, key finding, relevance, limitation, theme) using six themes: T1 governance structures and accountability; T2 automated discovery and classification; T3 metadata, lineage and catalogues as compliance infrastructure; T4 Canadian regulatory expectations; T5 human oversight of automation; T6 enforcement and the policy-to-data gap. The synthesis (Section IV) is organized by these themes, not by source.

C. Proof of concept as a structured test

Because the literature contains few column-level evaluations of PII classifiers on structured banking data (see Section IV-B), we built a small, reproducible POC to test specific claims. It is not a production system. Its design follows the course's advice that technical artifacts should serve the research question.

Environment. The official OpenMetadata 2.0.5 Docker Compose stack (server, PostgreSQL metadata store, Elasticsearch) plus a PostgreSQL 16 instance hosting the fictional bank: an OLTP database (`core_banking`, 10 tables) and a Kimball-style OLAP warehouse (`bank_dw`, 9 tables). Everything runs on a laptop in a 4 GB Docker VM with one command (`scripts/run_poc.sh`).

Data. A seeded generator created 1,500 customers, 2,336 accounts, 1,239 cards, 7,500 consent records, 55,058 transactions, 516 support tickets and 400 rows of a "legacy credit-union import" whose columns were never renamed (`fld_01`–`fld_04`). No real person is represented (reserved `example.*` e-mail domains, the fictional 555-01XX telephone exchange, random Luhn-valid identifiers). We deliberately planted defects that a PIPEDA program should detect: an ETL bug that keeps customers in a marketing audience after they withdraw consent; customers closed more than seven years ago; stored card-verification values (CVVs); and malformed postal codes.

Ground truth and metrics. Every one of the 145 columns was labelled **H** (high-risk identifier: SIN, card number, CVV, account or government-ID number; 7 columns), **D** (direct identifier: name, e-mail, phone, address, postal code, birth date, IP address, free text containing these; 18), **Q** (quasi-identifier; 10), **F** (financial; 5) or **N** (not personal; 105). A column flagged as sensitive was scored as a true positive if its label was H or D. We report precision, recall and F1 for three configurations: the out-of-the-box `PII` classification, a Canada-tuned `PIPEDA` classification, and the tuned classification after one round of human feedback.

IV. Evidence Synthesis

A. T1 — Data governance is a system of decision rights, not a tool

The literature agrees that data governance assigns decision rights and accountability for data assets [11]–[13]. Khatri and Brown frame it as decisions about data principles, quality, metadata, access and life cycle [11]; Abraham et al.'s review of 145 publications adds that governance mechanisms must be structural (roles), procedural (policies, processes) and relational (communication) [12]. Practitioner bodies of knowledge make the same point [14], and ISO/IEC 38505-1 places accountability for data with the governing body [15]. PIPEDA encodes this directly: Principle 4.1 requires a designated accountable individual. The consistent implication is that a catalogue can *record* decision rights (owners, stewards, reviewers) but cannot *create* them. Janssen et al. argue that trustworthy AI depends on this foundation, because algorithmic systems inherit the quality and provenance of their data [16].

B. T2 — Automated discovery works, but is context-dependent

Automated discovery of sensitive data is an active area of practice and invention: patents cover context-aware neural detection [17] and confidence scoring of personal-information findings [18], and Capital One reports that character-level neural models can classify sensitive columns at production throughput [19]. Yet three limitations recur. First, models trained on one jurisdiction's identifiers do not transfer: Truong et al. stress the scarcity of labelled financial datasets [19]. Second, sensitivity is contextual: the OPC treats financial information as generally sensitive but insists the assessment depends on circumstances [20]. Third, combinations of individually harmless fields re-identify people: Sweeney's *k*-anonymity work and Rocher et al.'s generative model show that a handful of quasi-identifiers (birth date, postal code, sex) identify most individuals [21], [22]. A classifier that labels columns one at a time cannot see this combination risk. We found no peer-reviewed benchmark of column-level PII classification on Canadian banking schemas; this evidence gap motivated the POC.

C. T3 — Metadata, lineage and catalogues are compliance infrastructure

Data catalogues improve findability and reuse of enterprise data [23]. Provenance research distinguishes *why*, *where* and *how* lineage [24]; for privacy, "where" lineage is what lets a bank answer an individual-access request (Principle 4.9) or scope a breach. BCBS 239 requires banks to aggregate risk data with documented lineage and controls [25], but a 2023 progress report found most global systemically important banks still had substantial work to do [26], which suggests that lineage at scale remains hard. Data contracts [27] and data-mesh "federated computational governance" [28] propose expressing obligations as machine-checkable rules. Because data quality is multi-dimensional and judged by fitness for use [29], such rules must encode the purpose of the data, not only its format. The common thread is *policy as metadata*: obligations become effective only when they are attached to specific assets and tested.

D. T4 — Canadian expectations converge on inventory, purpose and safeguards

PIPEDA's principles [2], the OPC's consent guidelines (express consent for sensitive information or unexpected uses) [30], breach record-keeping for 24 months [31], OSFI B-13's classification and discovery-scan expectations [4], and FINTRAC's five-year record and large-cash-reporting rules [10], [32] all presuppose an accurate inventory of personal information tied to purposes and retention periods. International frameworks agree: the NIST Privacy Framework's "Identify-P" function [33] and Privacy by Design's "privacy as the default" [34]. There is *tension* as well as convergence: FINTRAC requires retention that PIPEDA's limiting-retention principle would otherwise minimize, so retention rules must be purpose-specific rather than global.

E. T5 — Human oversight is necessary but fragile

AI-governance literature locates AI governance inside corporate, IT and data governance [35] and frameworks require human accountability for AI outputs [5], [36], [37]. Human-factors research warns that oversight degrades into *automation bias*: people over-trust reliable automation and stop checking it [38]. The IAPP reports that privacy and legal functions now hold primary responsibility for AI governance in many organizations [7], which places privacy professionals in the loop of AI classification decisions. The disagreement in the literature is about degree: vendors and patents emphasize automated confidence thresholds [18], whereas regulators and standards emphasize documented human review [5], [36].

F. T6 — The policy-to-data gap and new AI interfaces

Attribute-based access control (ABAC) lets policies key off attributes such as classification tags [39], and patents describe deriving access policies from tags and lineage [40]. But a catalogue's policies typically govern the catalogue itself; the OpenMetadata documentation is explicit that contract "security" sections are documentation, not enforcement [41]. A newer risk arises from AI assistants: MCP lets large-language-model agents call catalogue tools [9], and a systematic study identifies tool poisoning, over-privileged servers and data exfiltration among its threats [42].

TABLE I
SYNTHESIS: WHERE THE EVIDENCE CONVERGES, DIVERGES AND IS MISSING

Theme	Convergence	Divergence or tension	Implication for a Canadian bank
T1 Accountability	Governance assigns decision rights; a named person is accountable [2], [11], [12], [15]	Centralized vs. federated (domain) models [13], [28]	Catalogue records ownership; it cannot create it
T2 Automated discovery	Automation is necessary at bank scale [17]–[19]	Optimistic vendor claims vs. contextual sensitivity and re-identification [20]–[22]	Measure classifiers locally; treat combinations separately
T3 Metadata as infrastructure	Lineage and catalogues enable access requests, reporting and audits [23]–[25]	Lineage is hard to complete in practice [26]	Register every pipeline that moves PI
T4 Canadian expectations	Inventory, purpose, retention and safeguards [4], [30], [33]	PIPEDA minimization vs. FINTRAC retention [10]	Purpose-specific retention rules
T5 Human oversight	Humans remain accountable for AI outputs [5], [36], [37]	Automated thresholds vs. documented review [18]; automation bias [38]	Targeted, measured review of AI tags
T6 Enforcement gap	Attribute/tag-based control is feasible [39], [40]	Catalogue policy $\neq$ data policy [41]; new AI attack surface [42]	Generate enforcement from metadata; govern AI agents

G. Patterns across themes

Table I condenses the synthesis. Three patterns stand out. First, every source family converges on the need for an *inventory* of personal information tied to accountable owners, but they disagree on how much of that inventory can be produced automatically: patents and industry research are optimistic, regulators are cautious, and academic work warns about context and combination effects. Second, findings are strongly *context-dependent*: classifier performance, sensitivity, and even retention obligations change with jurisdiction and purpose. Third, a recurring and under-studied risk is the distance between *described* controls (metadata, contracts, policies in a catalogue) and *enforced* controls (permissions and transformations in the data platform itself).

H. Evidence gaps

We found (i) no published evaluation of OpenMetadata's classifier, (ii) no Canadian-identifier benchmark for structured data, and (iii) little empirical work on how privacy officers review AI-generated tags. We also found no independent, openly published evaluation of commercial governance platforms; analyst reports exist but are proprietary, so we did not rely on them. These gaps limit how far any conclusion can be generalized.

V. PROOF OF CONCEPT: DESIGN AND RESULTS

Fig. 1 summarizes the architecture. The governance model mapped each PIPEDA principle to concrete platform objects (Table II). All entities were created through the OpenMetadata REST API so the configuration is version-controlled and repeatable.

A. Result 1: Out-of-the-box classification is not Canadian-aware

OpenMetadata's auto-classification scans column names and sampled values with Microsoft Presidio recognizers and a spaCy named-entity model [8], [43]. Its 40 predefined recognizers in version 2.0.5 target U.S., U.K., Australian, Indian, Spanish, Italian and other identifiers; none targets the Canadian SIN, Canadian postal codes, provincial driver's licences or Canadian passports. On our data the baseline achieved precision 0.857 and recall 0.720 (Table III). The detail is more revealing than the totals: the SIN column was tagged only because an *Australian Tax File Number* pattern happened to match the NNN-NNN-NNN format, the unlabelled legacy SIN column was caught by a *U.S.*

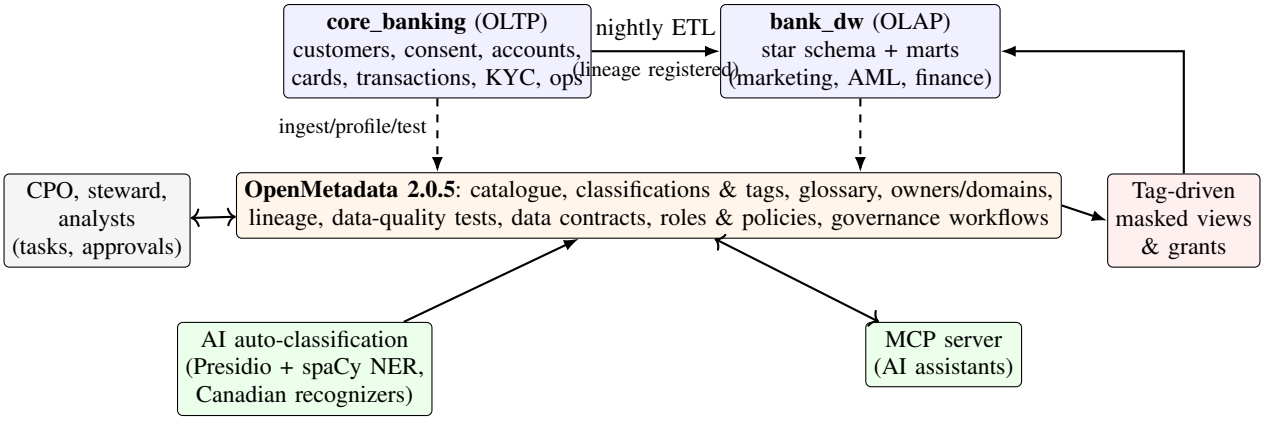


Fig. 1. POC architecture. OpenMetadata reads both databases with a read-only principal; AI classification proposes tags; people approve or correct them through workflows; tags then drive tests, policies, and generated database controls.

TABLE II
MAPPING PIPEDA SCHEDULE 1 PRINCIPLES TO POC CONTROLS

Principle	OpenMetadata control implemented in the POC
4.1 Accountability	Privacy Office team; CPO owns the `PIPEDA` classification and glossary; every table has an owning team and domain.
4.2 Identifying purposes	`PIPEDAPurpose` tags (account servicing, fraud prevention, regulatory reporting, marketing, analytics) on all 14 governed tables; purpose stated in a data contract.
4.3 Consent	Consent replicated to the warehouse; data-quality tests on the marketing mart; consent row filter in generated views.
4.4 Limiting collection	AI classification inventory of high-risk identifiers; test that no CVVs are stored.
4.5 Limiting use and retention	Table `retentionPeriod` (e.g., P7Y, P90D); tests for records past retention.
4.6 Accuracy	Format and uniqueness tests (postal code, e-mail, SIN).
4.7 Safeguards	Five-level sensitivity tags (HighRisk, DirectIdentifier, QuasiIdentifier, Financial, NonPersonal); tag-conditioned deny rules; tag-integrity rule; generated masked views.
4.8 Openness	13-term PIPEDA glossary approved through the glossary approval workflow.
4.9 Individual access	Column-level lineage from OLTP to every mart through a registered ETL pipeline; MCP lineage queries.
4.10 Challenging compliance	Recognizer-feedback workflow (steward reports, CPO decides) with a task audit trail.

TABLE III
AI AUTO-CLASSIFICATION AGAINST GROUND TRUTH (145 COLUMNS; POSITIVE = H OR D)

Configuration	Precision	Recall	F1	FP	FN	High-risk found
Out-of-the-box `PII`	0.857	0.720	0.783	3	7	4 of 7
Canada-tuned `PIPEDA`	0.893	1.000	0.943	3	0	7 of 7
Tuned + one round of steward feedback	1.000	1.000	1.000	0	0	7 of 7

ABA routing-number pattern, and telephone numbers were flagged by a *U.K. NHS-number* recognizer. Dates of birth were tagged *non-sensitive* by a generic date recognizer, while postal codes, account numbers and passport or licence numbers were missed. Correct outcomes for the wrong reasons are fragile: a format change would silently break them.

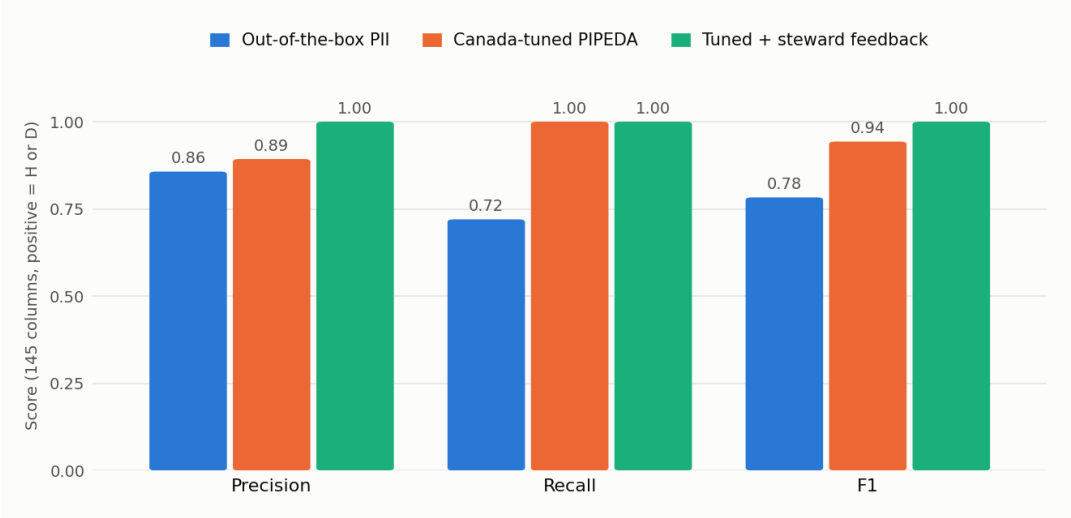


Fig. 2. Precision, recall and F1 of the three classification configurations (same data, same ground truth).

B. Result 2: Localization works, but required working around the product

We created a mutually exclusive `PIPEDA` classification whose tags carry 17 recognizers: regular expressions for formatted and unformatted SINs (with column-name context), Canadian postal codes, Ontario licences and Canadian passports; column-name rules; and selected Presidio recognizers. Recall rose to 1.000 and F1 to 0.943 (Table III, Fig. 2); all seven high-risk columns were found, including the SINs hidden in `fld_02`. Two product limitations surfaced. First, the open-source `metadata classify` command hard-codes the built-in `PII` classification [44], so recognizers on any other classification are silently ignored; we reused the official workflow class with a different classification filter (about 20 lines of code). Second, "custom" recognizers with validation code are not implemented, so SINs cannot be checksum-validated and any nine-digit pattern may match. These are exactly the kind of undocumented gaps a professional must test for before relying on a tool.

C. Result 3: Human feedback corrects errors and leaves a record

The tuned classifier's three false positives were `city` columns that the spaCy model read as person names. A data steward reported each as a false positive through the recognizer-feedback API, which started OpenMetadata's built-in `RecognizerFeedbackReviewWorkflow`; the CPO approved each task; the platform removed the tags and added a column-level exception to the responsible recognizer. A re-run produced no false positives against the H/D threshold (Table III). Exact five-level class accuracy, however, rose only from 0.959 to 0.966: once the person-name recognizer was excepted, a broader column-name rule re-tagged all three `city` columns as quasi-identifiers, which is correct for customer city but not for branch cities, which are public business addresses. Correcting one error exposed the over-breadth of another rule; feedback is an iterative process, not a one-time fix. Every AI-generated tag remains in the *Suggested* state until a person confirms it, which is the appropriate default for an accountable process. The glossary approval workflow behaved similarly: 13 PIPEDA terms were created in review and the CPO approved them; we also observed that editing a term under review cancels its approval task, a sensible safeguard that prevents approval of content that has changed.

D. Result 4: A living inventory of personal information

Combining the confirmed classifications with ownership, domain, purpose, retention and lineage metadata produced the inventory in Table IV and the flow map in Fig. 3, both generated from the OpenMetadata API rather than maintained by hand. Two observations matter for PIPEDA. First, the inventory immediately exposed over-collection: the legacy import table holds SINs under meaningless column names and has no identified purpose, so its retention was set to zero (`P0D`) pending deletion, and the card table stores CVVs that should never be retained. Second, the flow map shows that direct identifiers (names, e-mail addresses, dates of birth) propagate from the OLTP customer

TABLE IV
PERSONAL-INFORMATION INVENTORY GENERATED FROM THE CATALOGUE

Table	Sensitivity (roll-up)	Purposes	Retention	Owner
`core.customer`	HighRisk	Account servicing	P7Y	Data Engineering
`core.customer_consent`	—	Account servicing	P7Y	Privacy Office
`core.account`	HighRisk	Account servicing	P7Y	Data Engineering
`core.card`	HighRisk	Account servicing	P2Y	Data Engineering
`core.transaction`	DirectIdentifier	Account servicing, fraud prevention	P7Y	Data Engineering
`kyc.identity_document`	HighRisk	Regulatory reporting	P5Y	Fraud & AML
`ops.support_ticket`	DirectIdentifier	Account servicing	P2Y	Data Engineering
`ops.legacy_member_import`	HighRisk	*none identified*	P0D	Data Engineering
`dw.dim_customer`	DirectIdentifier	Analytics	P7Y	Data Engineering
`dw.dim_consent`	—	Marketing, analytics	P7Y	Privacy Office
`dw.fact_transaction`	Financial	Analytics, fraud prevention	P7Y	Data Engineering
`mart.marketing_campaign_audience`	DirectIdentifier	Marketing	P90D	Retail Marketing
`mart.aml_large_cash_txn`	DirectIdentifier	Regulatory reporting	P5Y	Fraud & AML
`mart.monthly_branch_activity`	Financial	Analytics	P10Y	Data Engineering

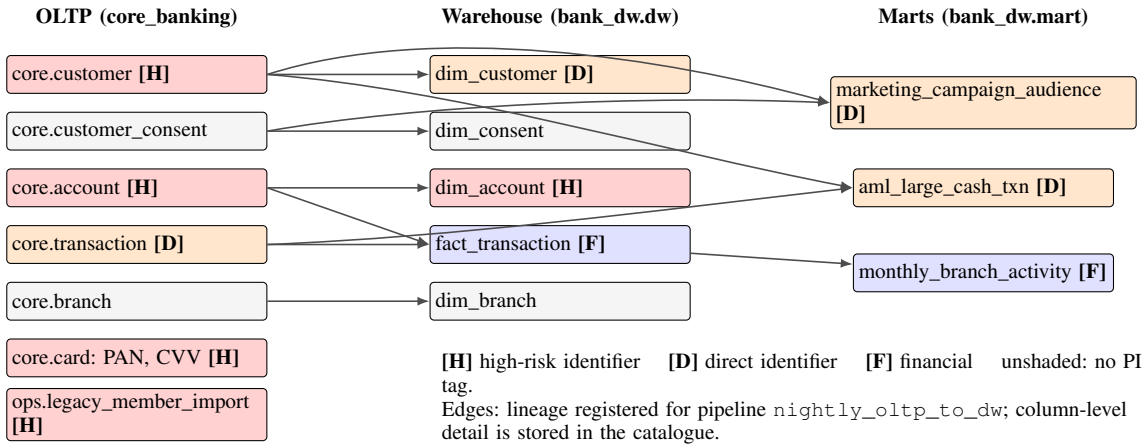


Fig. 3. Personal-information flow map derived from catalogue lineage and the most sensitive column tag of each table. The card and legacy tables have no downstream copies; the SIN stays in the OLTP layer.

table into three warehouse objects, whereas the SIN does not leave the OLTP layer. That is the kind of evidence a bank needs to answer an individual-access request (Principle 4.9) or to scope a breach notification under the real-risk-of-significant-harm test [31].

E. Result 5: Metadata tests exposed planted PIPEDA defects

Twelve data-quality tests, each named after the principle it checks, ran through OpenMetadata's test framework (Table V); failures automatically opened six incidents in the Incident Manager. The most instructive result concerns consent: a naive test that the audience's `consent_marketing` flag is true *passed*, while a test that cross-checks

TABLE V
PIPEDA DATA-QUALITY TESTS IN THE POC

Principle	Test (table)	Status	Observed
4.3 Consent	Audience flag `consent_marketing` is true (mart)	Pass	611 of 611 rows
4.3 Consent	Audience cross-checked against consent state (mart)	**Fail**	55 customers withdrew consent but remain
4.3 Consent	Withdrawal after capture; purpose not null (OLTP)	Pass	0 violations
4.4 Limiting collection	No CVV stored (`core.card`)	**Fail**	1,239 rows
4.4 Minimization	Warehouse keeps only 3-character FSA	Pass	—
4.5 Retention	Closed customers past 7 years purged (OLTP and DW)	**Fail**	38 rows in each
4.6 Accuracy	Canadian postal-code format (OLTP)	**Fail**	17 of 1,500 invalid
4.6 Accuracy	E-mail format (OLTP)	**Fail**	240 non-ASCII; rule under review
4.6 Accuracy	SIN uniqueness (OLTP)	Pass	1,473 unique
FINTRAC	Large-cash mart contains only $\geq$ \$10,000	Pass	0 violations

the audience against current consent state *failed* with 55 customers who had withdrawn consent. Compliance testing therefore needs the business rule, not just the column. The e-mail format test also failed for 240 addresses containing accented characters from French names: a case where a "failure" may reflect an over-strict rule rather than bad data, and where human judgement must decide.

F. Result 6: Catalogue policies work only on the catalogue

Tag-conditioned OpenMetadata policies behaved as designed once correctly attached: a marketing analyst was denied (HTTP 403) sample data, queries and profiles of tables tagged `PIPEDA.HighRisk` or `PIPEDA.DirectIdentifier`, while AML and privacy staff were allowed; and an organization-wide rule prevented anyone outside the Privacy and Data Governance offices from changing PIPEDA tags. Two findings temper this. First, the sample-data endpoint evaluated `matchAnyTag()` only against *table-level* tags, whereas the built-in permission debugger also counted column tags and reported "denied" when the endpoint allowed access; we therefore rolled the most sensitive column tag up to each table. Second, and more fundamentally, none of these policies stops a SQL user from querying the warehouse [41]. We closed the loop with a script that reads tags and purposes from the OpenMetadata API and generates PostgreSQL views and grants per business role: high-risk columns are dropped, direct identifiers are pseudonymized unless the table's purpose matches the role's purpose, and marketing views apply a current-consent row filter. The marketing role then saw 556 audience rows instead of 611, exactly removing the 55 withdrawn customers, and was denied access to the raw schemas.

G. Result 7: AI assistants can answer privacy questions — and change metadata

OpenMetadata's built-in MCP server exposed 15 tools. Through it, an AI assistant answered privacy-office questions grounded in the catalogue: which tables hold high-risk identifiers, where a customer's e-mail address flows (lineage through the registered ETL pipeline), whether the marketing mart passes its consent tests, and what "real risk of significant harm" means in the bank's glossary. The same server also exposes write tools (`patch_entity`, `create_entity`, `create_lineage`), so an agent connected with an over-privileged token could alter the very tags that drive safeguards, a concrete instance of the MCP threats catalogued by Hou et al. [42].

VI. Analysis

A. Answering the research question

Combining the literature with the POC, our answer is that an AI-assisted metadata platform can operationalize PIPEDA's principles *as a supervised control system*, not as an autonomous one. It is strongest where principles reduce to knowing and documenting: inventory (4.4), purpose (4.2), openness (4.8) and lineage for access requests and breach scoping (4.9). It is useful but incomplete for consent, retention and accuracy (4.3, 4.5, 4.6), where it can *detect* violations but the fix lies in pipelines and business processes. It is weakest for safeguards (4.7) unless catalogue metadata is wired into enforcement points the platform does not control.

B. SQ1: Accuracy is a property of the deployment, not the product

The jump from F1 0.783 to 0.943 came from local knowledge (Canadian formats and naming) rather than from more sophisticated AI. This supports the literature's view that classifier performance is context-dependent [19], [20] and implies that vendor accuracy claims are not transferable evidence. It also reframes the professional question: a bank that deploys a classifier without measuring it on its own schemas cannot know its false-negative rate, and false negatives, unlike false positives, are invisible. Our measured gains are optimistic (the same people wrote the generator and the recognizers), but the direction is robust: none of the baseline's Canadian-identifier hits relied on a Canadian rule.

C. SQ2: Metadata detects, people and pipelines correct

The consent result illustrates the central analytic point. The defect was visible only because consent state had been replicated, lineage documented and a cross-table rule written; a column-level check would have certified a non-compliant mart. Metadata platforms therefore shift effort from *finding* problems to *specifying* obligations precisely, which echoes the "policy as metadata" theme [27], [28]. They also make obligations auditable: each failed test opened an incident with an owner. What they cannot do is decide whether 240 accented e-mail addresses are an accuracy problem or an over-strict rule; that judgement belongs to accountable people.

D. SQ3: Human oversight must be designed, not assumed

OpenMetadata's defaults (tags as suggestions, reviewer-gated glossaries, feedback workflows with audit trails) embody good oversight design. But the literature on automation bias warns that a reviewer who approves hundreds of correct suggestions will eventually stop checking [38]. Oversight must therefore be targeted (review high-risk and low-confidence tags first), measured (track reviewer override rates), and periodically challenged with planted test cases, much as our ground truth did.

E. Alternative interpretations

One could argue that the POC shows the tool "works" and the remaining issues are configuration details. We disagree on two grounds. The undocumented hard-coded classification filter and the table-versus-column policy discrepancy are behaviours a reasonable administrator would not anticipate; relying on them without testing would be negligent. And the most consequential defects (consent, retention, CVV storage) were found by tests that encode legal reasoning, not by AI. A second interpretation is that commercial platforms avoid these limitations; we found no independent, openly published evidence for that claim, and the professional obligation to verify would be the same.

VII. Professional Responsibility Implications

Accountability. Delegating classification to AI does not delegate accountability: PIPEDA Principle 4.1 and OSFI E-23 both require a named human owner of outcomes [2], [5]. The CPO must own the classification taxonomy and the recognizer configuration as controlled artefacts, with change approval.

Privacy and data minimization. Auto-classification samples real rows and can store them in the catalogue. Sample storage should be disabled or masked for high-risk tables, or the catalogue becomes another copy of the data it is meant to protect, the same pattern that magnified the Desjardins breach [3].

TABLE VI
RECOMMENDATION ROADMAP TRACED TO EVIDENCE

#	Action	Owner	Horizon	Evidence (finding / source)
1	Measure classifier on labelled local schemas	CDO	0–3 mo	Result 1; [19], [20]
2	Add Canadian recognizers; verify they run	Data platform	0–3 mo	Results 1–2; [44]
3	Human confirmation of high-risk tags	CPO	0–3 mo	Result 3; [5], [38]
4	Lock down metadata and AI-agent access	Security	0–3 mo	Results 6–7; [4], [42]
5	PIPEDA rules as tests and contracts	Data stewards	3–12 mo	Result 5; [27], [30]
6	Generate enforcement from metadata	Data platform	3–12 mo	Result 6; [39], [41]
7	Complete pipeline lineage	Data engineering	3–12 mo	T3; [24], [26]
8	Quasi-identifier combination reviews	Privacy office	3–12 mo	T2; [21], [22]
9	Classifier under model-risk management	Model risk	12+ mo	T5; [5], [36]
10	Bill C-36 readiness using catalogue evidence	CPO	12+ mo	T4; [6]
11	Upstream fixes and Canadian recognizers	Engineering	12+ mo	Results 2, 6

Security. Metadata is security-relevant: whoever can remove a tag can disable a safeguard. Tag-integrity rules, separation of duties, alerting on tag changes, and least-privilege tokens for ingestion bots and AI agents are required [4], [42].

Fairness and equity. Recognizer quality varies by name origin and language; spaCy mis-read city names as people, and accented French names failed a naive e-mail rule. Controls that work less well for some customers (for example francophone or immigrant customers) create unequal privacy protection and should be tested for.

Professional obligations and honesty. Engineers and privacy professionals must report limitations they discover, including to the open-source maintainers, rather than presenting a tool as compliant. Equally, results from synthetic data must be presented as such.

Organizational and public impact. A bank that can trace personal information end-to-end can honour access requests, scope breaches quickly and demonstrate compliance to regulators. Over-reliance on automation, in contrast, risks a false sense of compliance that is worse than acknowledged ignorance.

VIII. RECOMMENDATIONS

Recommendations are addressed to the CPO (accountable executive), the Chief Data Officer (CDO) and data-platform engineering, and are sequenced by horizon. Each is traceable to a finding (Table VI); Table VII proposes who is responsible (R), accountable (A), consulted (C) and informed (I) for the recurring governance activities, including the AI components.

A. Immediate (0–3 months)

1) **Measure before you trust (CDO).** Build a labelled sample of real schemas, as our ground truth did, and report precision and recall of auto-classification, with recall on high-risk identifiers as the acceptance criterion.

TABLE VII
PROPOSED RACI FOR AI-ASSISTED PRIVACY GOVERNANCE

Activity	CPO	Steward	Engineer	Business user	AI component
Maintain classification taxonomy and recognizers	A	R	C	I	—
Propose sensitivity tags	I	C	I	—	R (suggests only)
Confirm or reject high-risk tags	A	R	I	—	—
Report a misclassification	I	R	R	R	—
Approve glossary terms and purposes	A/R	C	I	C	—
Register lineage and retention for pipelines	I	C	A/R	—	—
Investigate failed PIPEDA tests (incidents)	A	R	R	I	—
Grant data access (generated controls)	A	C	R	I	—
Answer catalogue questions via MCP	I	C	—	R	R (read-only)

2) **Localize the classifier (data platform).** Add Canadian recognizers (SIN, postal code, provincial health and licence numbers, passport, transit/institution/account formats) and column-name rules for legacy naming; verify that the deployed version actually evaluates them.
3) **Keep AI tags as suggestions (CPO).** Require human confirmation for high-risk tags; use the feedback workflow for corrections so that every decision is attributable.
4) **Lock down metadata (security).** Apply tag-integrity rules, roll sensitivity up to table level for policy evaluation, disable sample storage for high-risk tables, and connect AI assistants only through least-privilege, read-only identities.

B. Medium term (3–12 months)

5) **Codify PIPEDA as tests (data stewards).** Express consent, retention and minimization rules as data-quality tests and data contracts on every mart that holds personal information, with incident ownership.
6) **Close the policy-to-data gap (data platform).** Generate warehouse masking, row filters and grants from catalogue tags and purposes, and alert when catalogue and database permissions diverge.
7) **Complete lineage (data engineering).** Register every pipeline that moves personal information so that access requests and breach scoping can be answered from lineage.
8) **Assess combination risk (privacy office).** Review tables that combine several quasi-identifiers, which column-level classifiers cannot judge [21], [22].

C. Longer term (12+ months)

9) **Treat the classifier as a model (model-risk management).** Bring it under OSFI E-23 governance: inventory, validation, monitoring and periodic re-testing.
10) **Prepare for Bill C-36 (CPO).** Use the catalogue's purpose and lineage records as the evidence base for whatever accountability and de-identification obligations the successor law imposes [6].
11) **Contribute upstream (engineering).** Report the hard-coded classification filter and policy-evaluation discrepancy to the OpenMetadata project, and contribute Canadian recognizers, reducing risk for the whole sector.

IX. LIMITATIONS

Synthetic data and optimistic scores. The bank, its schemas and its defects were designed by the authors, who also wrote the recognizers; the tuned and post-feedback scores are therefore upper bounds, and real legacy systems will be messier. **Small sample.** With 145 columns and 25 positives, a single misclassification moves recall by four points; no confidence intervals are claimed. **Single product and version.** Findings describe OpenMetadata 2.0.5 open source in its default configuration; later releases or commercial editions may differ. **Structured data only.** Documents, images and free-text archives, where much sensitive information lives, were out of scope. **Scripted personas.** Approvals were scripted to make the POC reproducible; they demonstrate workflow mechanics, not real

reviewer behaviour. **Legal interpretation.** Mappings to PIPEDA reflect the authors' reading of public guidance, not legal advice; the law may change with Bill C-36. **Evidence base.** Few peer-reviewed studies evaluate catalogue-based privacy controls, and commercial-platform evidence is largely proprietary.

X. Conclusion

AI-assisted metadata platforms can give a Canadian bank something PIPEDA has always required but few banks have achieved: a living inventory of personal information linked to purposes, owners, lineage, tests and retention rules. Our evidence shows that this capability is real but conditional. Out of the box, the AI did not recognize Canadian identifiers; with local tuning and human feedback it did, and metadata tests exposed consent, retention and collection failures that a column-level view would miss. The platform, however, governs descriptions of data rather than the data itself, and its newest interface, AI assistants through MCP, is also a new attack surface. The defensible course is to treat AI classification as a monitored model inside an accountable governance system: measure it, localize it, keep people responsible for its decisions, and connect its outputs to real enforcement.

Acknowledgment

The authors thank the GNG/ELG 5301 teaching team for feedback. See Appendix D for the generative-AI use statement.

References

[1] R. Kimball and M. Ross, *The Data Warehouse Toolkit: The Definitive Guide to Dimensional Modeling*, 3rd ed. Indianapolis, IN, USA: Wiley, 2013, iSBN 978-1-118-53080-1.

[2] Government of Canada, "Personal information protection and electronic documents act, S.C. 2000, c. 5," Justice Laws Website. [Online]. Available: https://laws-lois.justice.gc.ca/eng/acts/P-8.6/, 2000, current to 2026-09-30; accessed Oct. 21, 2026.

[3] Office of the Privacy Commissioner of Canada, "Investigation into Desjardins' compliance with PIPEDA following a breach of personal information between 2017 and 2019," OPC, Gatineau, QC, Canada, PIPEDA Findings 2020-005, Dec. 2020, [Online]. Available: https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2020/pipeda-2020-005/.

[4] Office of the Superintendent of Financial Institutions, "Guideline B-13: Technology and cyber risk management," [Online]. Available: https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management, 2022, published Jul. 2022, effective Jan. 1, 2024; accessed Oct. 21, 2026.

[5] ——, "Guideline E-23: Model risk management (2027)," [Online]. Available: https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/guideline-e-23-model-risk-management-2027, 2025, final Sep. 11, 2025, effective May 1, 2027; accessed Oct. 21, 2026.

[6] Parliament of Canada, "Bill C-36 (45-1), an act to enact the protecting privacy and consumer data act, to amend the Personal Information Protection and Electronic Documents Act and to make amendments to other acts," LEGISinfo. [Online]. Available: https://www.parl.ca/legisinfo/en/bill/45-1/c-36, 2026, first reading Jun. 15, 2026; accessed Oct. 21, 2026.

[7] R. Sentinella, E. Fuelle, A. Casovan, and J. Jones, "AI governance profession report 2025," International Association of Privacy Professionals and Credo AI, Portsmouth, NH, USA, Tech. Rep., Apr. 2025, [Online]. Available: https://www.iapp.org/resources/article/ai-governance-profession-report.

[8] Microsoft, "Presidio: Data protection and de-identification SDK," [Online]. Available: https://microsoft.github.io/presidio/, 2026, accessed Oct. 21, 2026.

[9] OpenMetadata, "MCP server (v2.0.x)," [Online]. Available: https://docs.open-metadata.org/v2.0.x/how-to-guides/mcp, 2026, accessed Oct. 21, 2026.

[10] Financial Transactions and Reports Analysis Centre of Canada, "Record keeping requirements for financial entities," [Online]. Available: https://fintrac-canafe.canada.ca/guidance-directives/recordkeeping-document/record/fin-eng, 2026, accessed Oct. 21, 2026.

[11] V. Khatri and C. V. Brown, "Designing data governance," *Commun. ACM*, vol. 53, no. 1, pp. 148–152, 2010.

[12] R. Abraham, J. Schneider, and J. vom Brocke, "Data governance: A conceptual framework, structured review, and research agenda," *Int. J. Inf. Manage.*, vol. 49, pp. 424–438, Dec. 2019.

[13] B. Otto, "Organizing data governance: Findings from the telecommunications industry and consequences for large service providers," *Commun. Assoc. Inf. Syst.*, vol. 29, 2011.

[14] DAMA International, *DAMA-DMBOK: Data Management Body of Knowledge*, 2nd ed. Basking Ridge, NJ, USA: Technics Publications, 2024, iSBN 978-1-63462-234-9.

[15] ISO/IEC, "Information technology—governance of IT—governance of data—part 1: Application of ISO/IEC 38500 to the governance of data," International Organization for Standardization, Geneva, Switzerland, Standard ISO/IEC 38505-1:2026, 2026.

[16] M. Janssen, P. Brous, E. Estevez, L. S. Barbosa, and T. Janowski, "Data governance: Organizing data for trustworthy artificial intelligence," *Gov. Inf. Q.*, vol. 37, no. 3, p. 101493, 2020.

[17] M. Qiao, Y. J. Ong, R. Routray, and R. C. Raphael, "Context aware sensitive information detection," U.S. Patent 10 984 316 B2, Apr. 2021, assignee: International Business Machines Corp.; filed Jun. 19, 2017.

[18] Y. Enuka, N. Vax, E. Sacharov, and I. Apel, "Machine learning system and methods for determining confidence levels of personal information findings," U.S. Patent 11 113 633 B2, Sep. 2021, assignee: BigID Inc.; priority Aug. 13, 2018.

[19] A. Truong, A. Walters, and J. Goodsitt, "Sensitive data detection with high-throughput neural network models for financial institutions," arXiv:2012.09597 [cs.LG], Dec. 2020, [Online]. Available: https://arxiv.org/abs/2012.09597.

[20] Office of the Privacy Commissioner of Canada, "Interpretation bulletin: Sensitive information," [Online]. Available: https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/pipeda-compliance-help/pipeda-interpretation-bulletins/interpretations_10_sensible/, 2022, issued May 16, 2022; accessed Oct. 21, 2026.
[21] L. Sweeney, "k-anonymity: A model for protecting privacy," *Int. J. Uncertainty, Fuzziness Knowl.-Based Syst.*, vol. 10, no. 5, pp. 557–570, 2002.
[22] L. Rocher, J. M. Hendrickx, and Y.-A. de Montjoye, "Estimating the success of re-identifications in incomplete datasets using generative models," *Nature Commun.*, vol. 10, p. 3069, 2019.
[23] C. Labadie, C. Legner, M. Eurich, and M. Fadler, "FAIR enough? Enhancing the usage of enterprise data with data catalogs," in *Proc. IEEE 22nd Conf. Business Informatics (CBI)*, Antwerp, Belgium, 2020, pp. 201–210.
[24] M. Herschel, R. Diestelkämper, and H. Ben Lahmar, "A survey on provenance: What for? What form? What from?" *VLDB J.*, vol. 26, no. 6, pp. 881–906, 2017.
[25] Basel Committee on Banking Supervision, "Principles for effective risk data aggregation and risk reporting," Bank for International Settlements, Basel, Switzerland, Tech. Rep. BCBS 239, Jan. 2013, [Online]. Available: https://www.bis.org/publ/bcbs239.pdf.
[26] ——, "Progress in adopting the principles for effective risk data aggregation and risk reporting," Bank for International Settlements, Basel, Switzerland, Tech. Rep., Nov. 2023, [Online]. Available: https://www.bis.org/bcbs/publ/d559.htm.
[27] A. Jones, *Driving Data Quality with Data Contracts*. Birmingham, U.K.: Packt Publishing, 2023, iSBN 978-1-83763-500-9.
[28] Z. Dehghani, *Data Mesh: Delivering Data-Driven Value at Scale*. Sebastopol, CA, USA: O'Reilly Media, 2022, iSBN 978-1-4920-9239-1.
[29] R. Y. Wang and D. M. Strong, "Beyond accuracy: What data quality means to data consumers," *J. Manage. Inf. Syst.*, vol. 12, no. 4, pp. 5–33, 1996.
[30] Office of the Privacy Commissioner of Canada, "Guidelines for obtaining meaningful consent," [Online]. Available: https://www.priv.gc.ca/en/privacy-topics/collecting-personal-information/consent/gl_omc_201805/, 2018, issued May 2018, modified Aug. 11, 2025; accessed Oct. 21, 2026.
[31] Government of Canada, "Breach of security safeguards regulations, SOR/2018-64," Justice Laws Website. [Online]. Available: https://laws-lois.justice.gc.ca/eng/regulations/SOR-2018-64/, 2018, registered Mar. 27, 2018; accessed Oct. 21, 2026.
[32] Financial Transactions and Reports Analysis Centre of Canada, "Reporting large cash transactions to FINTRAC," [Online]. Available: https://fintrac-canafe.canada.ca/guidance-directives/transaction-operation/lctr-doie/lctr-doie-eng, 2026, accessed Oct. 21, 2026.
[33] National Institute of Standards and Technology, "NIST privacy framework: A tool for improving privacy through enterprise risk management, version 1.0," NIST, Gaithersburg, MD, USA, Cybersecurity White Paper CSWP 01162020, Jan. 2020.
[34] A. Cavoukian, "Privacy by design: The 7 foundational principles," Information and Privacy Commissioner of Ontario, Toronto, ON, Canada, Tech. Rep., Jan. 2011, originally published Aug. 2009, revised Jan. 2011.
[35] M. Mäntymäki, M. Minkkinen, T. Birkstedt, and M. Viljanen, "Defining organizational AI governance," *AI Ethics*, vol. 2, no. 4, pp. 603–609, 2022.
[36] E. Tabassi, "Artificial intelligence risk management framework (AI RMF 1.0)," National Institute of Standards and Technology, Gaithersburg, MD, USA, Tech. Rep. NIST AI 100-1, Jan. 2023.
[37] ISO/IEC, "Information technology—artificial intelligence—management system," International Organization for Standardization, Geneva, Switzerland, Standard ISO/IEC 42001:2023, 2023.
[38] R. Parasuraman and V. Riley, "Humans and automation: Use, misuse, disuse, abuse," *Hum. Factors*, vol. 39, no. 2, pp. 230–253, 1997.
[39] V. C. Hu, D. Ferraiolo, R. Kuhn, A. Schnitzer, K. Sandlin, R. Miller, and K. Scarfone, "Guide to attribute based access control (ABAC) definition and considerations," National Institute of Standards and Technology, Gaithersburg, MD, USA, NIST Special Publication 800-162, Jan. 2014.
[40] K. Kakui, "Data access control system and data access control method," U.S. Patent 11 556 661 B2, Jan. 2023, assignee: Hitachi, Ltd.; filed Sep. 16, 2020.
[41] OpenMetadata, "Data contract specification (v2.0.x)," [Online]. Available: https://docs.open-metadata.org/v2.0.x/how-to-guides/data-contracts/spec, 2026, accessed Oct. 21, 2026.
[42] X. Hou, Y. Zhao, S. Wang, and H. Wang, "Model Context Protocol (MCP): Landscape, security threats, and future research directions," *ACM Trans. Softw. Eng. Methodol.*, vol. 35, no. 10, pp. 1–37, 2026.
[43] OpenMetadata, "Auto-classification in OpenMetadata (v2.0.x)," [Online]. Available: https://docs.open-metadata.org/v2.0.x/how-to-guides/data-governance/classification/auto-classification, 2026, accessed Oct. 21, 2026.
[44] OpenMetadata contributors, "OpenMetadata 2.0.5 release, ingestion/src/metadata/workflow/classification.py," GitHub. [Online]. Available: https://github.com/open-metadata/OpenMetadata/blob/2.0.5-release/ingestion/src/metadata/workflow/classification.py, 2026, released Oct. 8, 2026; accessed Oct. 21, 2026.
[45] OpenMetadata, "Advanced guide for roles and policies (v2.0.x)," [Online]. Available: https://docs.open-metadata.org/v2.0.x/how-to-guides/admin-guide/roles-policies, 2026, accessed Oct. 21, 2026.

APPENDIX A
EVIDENCE TABLE (ABBREVIATED)

Source	Type	Key finding	Relevance / limitation	Theme
Khatri & Brown [11]	Journal	Five decision domains incl. metadata, access, life cycle	Foundational; pre-dates AI catalogues	T1

Source	Type	Key finding	Relevance / limitation	Theme
Abraham et al. [12]	Journal	Structural, procedural, relational mechanisms (145 sources)	Strong review; not finance-specific	T1
Otto [13]	Journal	Organizational forms of data governance	Single-industry case	T1
Janssen et al. [16]	Journal	13 principles for governing data for trustworthy AI	Public-sector focus	T1, T5
DAMA [14]	Handbook	Data-management body of knowledge	Practitioner consensus	T1, T3
Truong et al. [19]	Preprint	Neural column classification at bank scale	Industry, not peer-reviewed	T2
IBM patent [17]	Patent	Context-aware BiLSTM detection with retraining	Claims, not evaluation	T2
BigID patent [18]	Patent	Confidence levels for PI findings	Commercial claims	T2, T5
Sweeney [21]; Rocher et al. [22]	Journal	Quasi-identifiers re-identify individuals	Motivates combination risk	T2
OPC bulletin [20]	Regulator	Sensitivity is contextual; financial data generally sensitive	Non-binding guidance	T2, T4
Labadie et al. [23]	Conference	Catalogue initiatives and enterprise value	Little privacy evidence	T3
Herschel et al. [24]	Journal	Taxonomy of provenance	Technical survey	T3
BCBS 239 [25], [26]	Standard / report	Lineage and aggregation duties; slow adoption	Bank-specific	T3, T4
Jones [27]; Dehghani [28]	Books	Contracts and computational governance	Practitioner, limited evaluation	T3, T6
PIPEDA [2]; regs [31]	Statute	Ten principles; 24-month breach records	Binding law	T4
OPC Desjardins [3]	Regulator	Breach from accountability, retention, safeguard gaps	Canadian bank precedent	T4, T6
OSFI B-13 [4]; E-23 [5]	Regulator	Classification, discovery scans; AI model risk	FRFI scope	T4, T5
FINTRAC [10], [32]	Regulator	5-year records; $10k LCTR	Conflicts with minimization	T4
Bill C-36 [6]	Bill	Proposed successor to PIPEDA Part 1	Not law	T4
NIST PF [33]; PbD [34]	Standards	Inventory, privacy by default	Voluntary	T4
Mäntymäki et al. [35]	Journal	AI governance within data/IT governance	Conceptual	T5
Parasuraman & Riley [38]	Journal	Automation bias and misuse	Not privacy-specific	T5
NIST AI RMF [36]; ISO 42001 [37]	Standards	Human oversight of AI	Voluntary	T5
IAPP [7]	Professional	Privacy/legal lead AI governance (22% each)	Survey, self-report	T5
NIST ABAC [39]; Hitachi patent [40]	Standard / patent	Attribute- and lineage-driven access control	Design, not evaluation	T6
Hou et al. [42]	Journal	MCP threat taxonomy	Fast-moving field	T6
OpenMetadata docs [9], [41], [43], [45]; source [44]	Documentation	Product behaviour (verified in POC)	Vendor-maintained	T2, T6

APPENDIX B
SEARCH LOG (SUMMARY)

Database / site	Query (abridged)	Screened	Kept
Crossref, Scholar	"data governance" AND (framework OR review)	40	5
Crossref, IEEE, ACM	("data catalog" OR lineage OR provenance) AND (enterprise OR privacy)	30	3
Scholar, arXiv	(PII OR "sensitive data") AND (detection OR classification) AND (column OR structured OR financial)	35	3
Crossref, IEEE	"automation bias"; AI AND privacy AND compliance checking	15	1
arXiv, ACM	"Model Context Protocol" AND security	12	1
Google Patents	sensitive data detection; personal information confidence; tag lineage access control	25	3
Justice Laws, OPC, OSFI, FINTRAC, Parliament	PIPEDA; consent; sensitive; Desjardins; B-13; E-23; record keeping; C-36	22	10
NIST, ISO, BIS, IPC	privacy framework; AI RMF; 27701; 42001; 38505; BCBS 239; Privacy by Design	18	8
IAPP, Gartner, publishers	AI governance report; governance platforms; data contracts; data mesh; DMBOK; Kimball	15	5
OpenMetadata, Microsoft	auto-classification; roles and policies; data contracts; MCP; Presidio	10	6

APPENDIX C
REPRODUCIBILITY

The POC runs end-to-end with `poc/scripts/run_poc.sh` (about 15–20 minutes on a laptop with Docker Desktop and 4 GB of VM memory). It uses the unmodified official OpenMetadata 2.0.5 compose file plus an overlay; all generated evidence (classification snapshots, workflow audit, access-control results, enforcement checks, MCP transcript, compliance summary) is written to `poc/results/`. A full reset-and-rerun reproduced every figure reported here.

APPENDIX D
GENERATIVE-AI USE STATEMENT

[To be completed and verified by the team before submission.] Tool: Claude (Anthropic), used through Claude Code on October 21, 2026. Purpose: assistance with building the proof-of-concept code, locating candidate sources, and producing a first draft of this report. Verification: every reference was checked against a DOI, publisher record or official URL; every POC number was regenerated by a clean re-run; the team must (i) re-read each cited source to confirm it supports the claim attached to it, (ii) rewrite the analysis, professional-responsibility and recommendation sections in its own words and judgement, and (iii) record individual contributions. AI did not replace source evaluation, interpretation or authorship responsibilities, which remain with the team.